Access Control Policy

Date	Version	Author	Description	Approved By	Last Updated	Review Frequency	Next Review

Purpose

This policy establishes rules and responsibilities for managing user access to information systems, applications, and data to ensure that only authorised individuals have access to relevant resources based on business need and job role.

Scope

Applies to all employees, contractors, and third-party users of systems, applications, and networks within the ISMS scope of Stark Industries Inc., including the SaaS platform and supporting infrastructure.

Access Control Principles

- **Least Privilege**: Users are granted the minimum access necessary to perform their duties.
- **Need to Know**: Access to confidential and restricted information is limited to those with a justified business requirement.
- **Role-Based Access Control (RBAC)**: Access is defined and granted according to job function.
- **Segregation of Duties:** Critical tasks (e.g. code changes, production deployments, financial approvals) must be split among multiple users to prevent errors and reduce fraud risk.

User Access Management

1) User Registration and De-registration
    - All user accounts must be formally requested, approved, and documented.
    - Access is removed immediately when a user leaves the company or changes roles.

2) User Registration and De-registration
    - All user accounts must be formally requested, approved, and documented.
    - Access is removed immediately when a user leaves the company or changes roles.
3) User Registration and De-registration

- All user accounts must be formally requested, approved, and documented.
- Access is removed immediately when a user leaves the company or changes roles.

User Responsibilities (A.5.16)

- Users must:
    - Keep credentials confidential and secure
    - Report suspected unauthorised access immediately
    - Not share login credentials or reuse passwords across systems

Access Review and Monitoring

- Access to key systems is reviewed:
    - Quarterly for privileged accounts
    - Annually for all other users
- Inactive accounts are disabled or removed after 30 days of inactivity.

Remote Access and Third Parties

- Remote access (e.g. VPN, SSH) is only permitted through approved, secure channels.
- Third-party access (e.g. vendors) requires:
    - NDA or contract in place
    - Time-bound, monitored access
    - Logging and review of actions

Authentication Requirements

- All systems require strong authentication (e.g. minimum 12-character passwords).
- MFA (Multi-Factor Authentication) is enforced for:
    - Admin accounts
    - Cloud environments (e.g. AWS, GitHub)
    - Remote access

Access to Sensitive Data

- Access to confidential or restricted data (e.g. source code, CI/CD, databases) must be:
    - Logged
    - Reviewed for anomalies
    - Limited to individuals with signed access agreements

Segregation of Duties Implementation (A.5.3)

Function	Primary Role	Secondary/Approval Role
Code development and deployment	Developer	Infrastructure Engineer (approves production deployment)
Access approvals for critical systems	System Owner	Information Security Manager
Backup and restoration	Infrastructure Engineer	GRC Analyst or IT Engineer

Enforcement

- Violations of this policy may result in:
    - Immediate access revocation
    - Disciplinary action
    - Potential legal consequences

Roles and Responsibilities

Role	Responsibility
Information Security Manager	Oversees policy enforcement and reviews
GRC Analyst	Conducts access reviews, tracks approvals, supports audits
System Owners	Approve and monitor access to their respective assets
All Users	Follow access procedures and report issues promptly

Policy Review

- This policy is reviewed **annually** or upon significant change to the environment or regulatory requirements.